

常见网络攻击技术深度解析

从入门到精通：全面剖析网络安全威胁

汇报人：1025040809 吴继涛

CYBER SECURITY THREAT ANALYSIS

目录CONTENTS

01 常见网络攻击技术概述

- 信息收集与侦察 | 拒绝服务攻击 | 局域网攻击
- 恶意代码 | 社会工程学攻击

02 Web常见攻击技术深度解析

- SQL注入 | XSS跨站脚本
- CSRF跨站请求伪造 | 文件上传漏洞

PART 01

常见网络攻击技术概述

CYBER SECURITY THREAT OVERVIEW

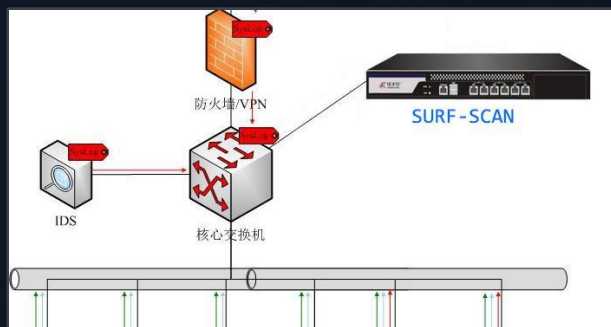
01 信息收集与侦察 (Reconnaissance)

信息收集是网络攻击的起点，攻击者通过各种手段尽可能多地收集目标信息，以便发现潜在的攻击面和漏洞，为后续的渗透和攻击做足准备。

```
WARNING: Many people use -Pn w/Idlescan to prevent pings from their true IP. On the other hand, timing info Nmap gains from pings can allow for faster, more reliable scans.
Starting Nmap 7.80 ( https://nmap.org ) at 2020-04-13 08:43 EDT
Idle scan using zombie www.baidu.com (39.156.66.18:80); Class: Incremental
Nmap scan report for 192.168.1.131
Host is up (0.10s latency).
Not shown: 988 closed/filtered ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
5432/tcp  open  postgresql
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:B5:A6:15 (VMware)
```

端口扫描 (Port Scanning)

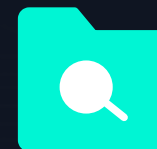
向目标主机的一系列端口发送探测数据包，判断哪些端口开放，并推断端口运行的服务类型和版本，寻找可利用的入口。常用工具：Nmap。



漏洞扫描 (Vulnerability Scanning)

使用自动化工具对目标系统进行全面探测，与已知漏洞库比对，识别系统中存在的各类安全缺陷和配置错误。常用工具：Nessus

。



目录遍历 (Directory Traversal)

利用Web应用对用户输入验证不足的缺陷，通过构造特殊路径（如../）来突破访问限制，尝试读取Web根目录之外的敏感文件或目录。

02 拒绝服务攻击 (Denial-of-Service, DoS)

DoS攻击的目的不是窃取信息或控制系统，而是使目标服务不可用，破坏其正常运营。其核心在于通过消耗资源，让合法用户无法获得服务。

DoS (Denial-of-Service) · 单点攻击

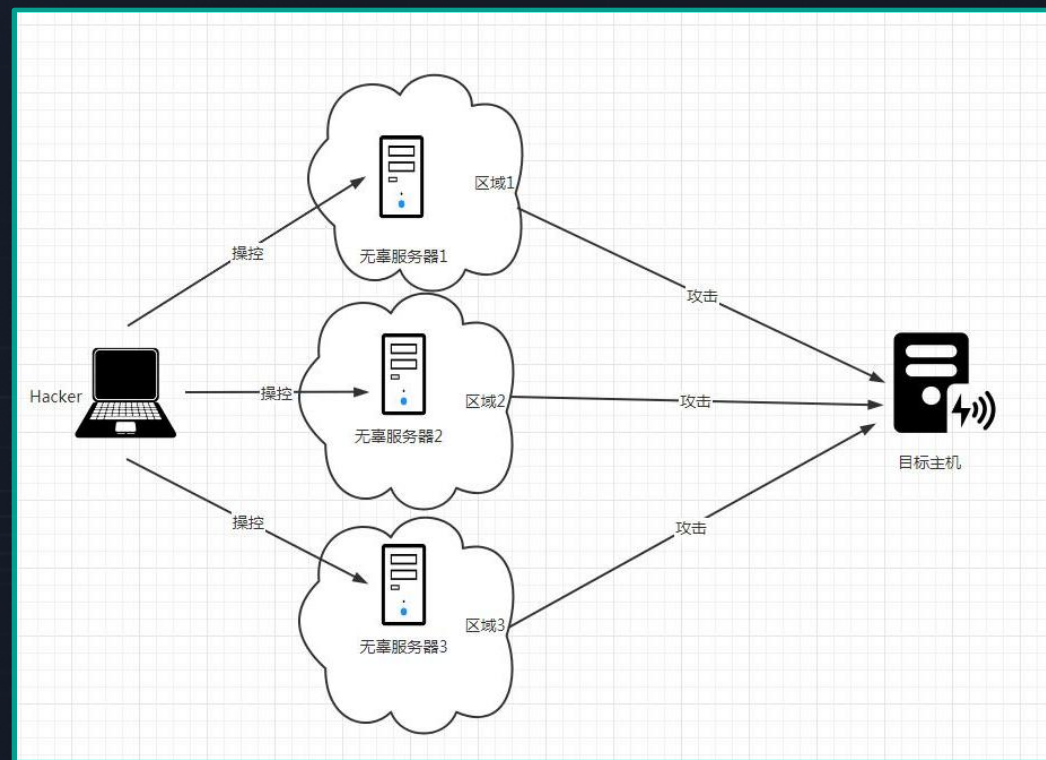
单一攻击源向目标发送大量请求或恶意流量，直接耗尽目标的网络带宽、连接数或系统资源。典型案例如：SYN Flood攻击。

DDoS (Distributed DoS) · 分布式攻击

DoS的升级版。攻击者利用“僵尸网络”控制成千上万的傀儡主机，从全球各地同时向目标发起攻击，汇聚成巨大的流量洪流，破坏力极强。

CC攻击 (Challenge Collapsar) · 应用层攻击

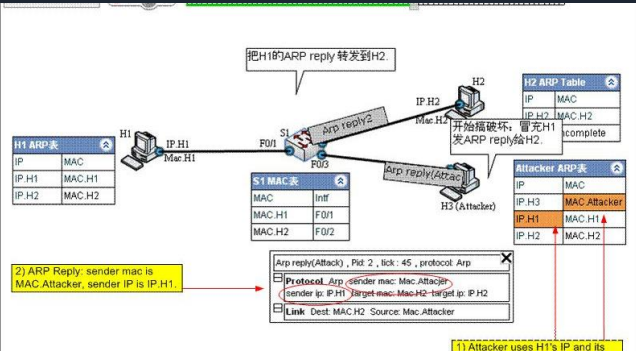
模拟正常用户的合法请求，专门针对动态页面发起高频访问，直接消耗服务器的CPU、内存或数据库连接，让服务“忙死”。



DDoS 攻击原理示意图：利用傀儡网络发起集群攻击

03 局域网攻击 (LAN Attacks)

这类攻击主要发生在局域网内部，利用局域网协议的信任机制进行欺骗和窃听，是内网环境中最为隐蔽且危害极大的威胁类型。



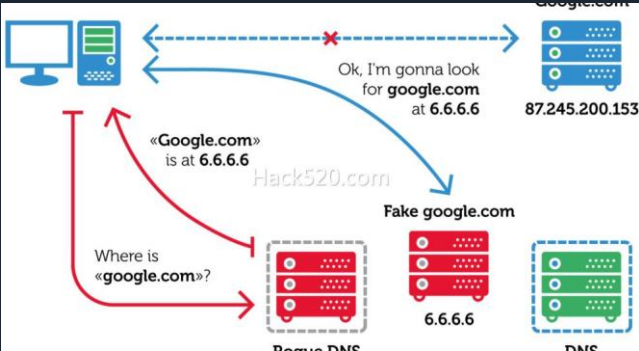
ARP欺骗 (ARP Spoofing)

攻击者向局域网内发送伪造的ARP应答包，将网关的IP地址与自己的MAC地址绑定，使其他主机误将攻击者当作网关，从而截获所有网络流量，实现窃听或篡改。



中间人攻击 (MitM)

攻击者秘密将自己放置在通信双方之间，拦截、窃听并可能篡改双方的通信内容。ARP欺骗是在局域网内实现中间人攻击最常用的手段之一。

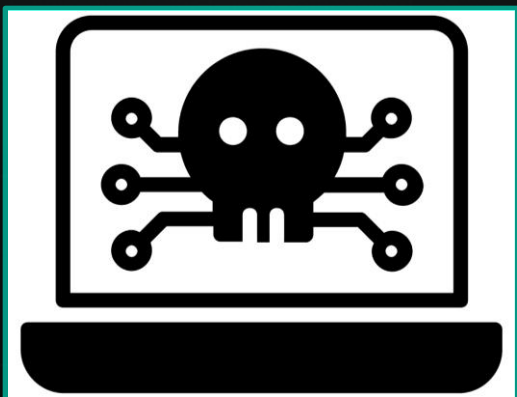


DNS劫持 (DNS Hijacking)

攻击者通过篡改设备的DNS配置，或污染局域网DNS服务器的缓存，将用户请求解析到恶意IP地址。这会将用户的正常访问导向钓鱼网站，导致信息泄露。

04 恶意代码 (Malware)

恶意代码是指在未经用户授权的情况下，旨在破坏系统、窃取信息或执行其他恶意操作的程序，是网络攻击中最常见的“武器”。



病毒 (Virus)

具有自我复制能力，需要依附于宿主文件（如文档、程序）才能传播，感染后破坏或篡改数据。

蠕虫 (Worm)

无需依附宿主，是独立的可执行程序。利用网络协议或系统漏洞主动在网络中快速自我复制和传播。

木马 (Trojan Horse)

伪装成合法、有用的软件诱骗用户执行。一旦运行，就会在系统中打开“后门”，让攻击者远程控制电脑。

勒索软件 (Ransomware)

通过高强度加密算法锁定用户的重要文件（文档、照片、数据库等），使数据无法访问。随后弹出勒索信息，要求支付赎金以换取解密密钥。

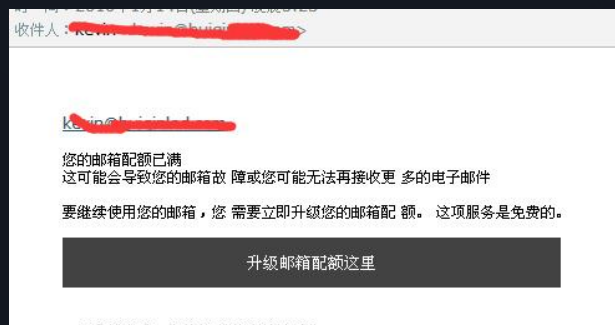
间谍软件 (Spyware)

在用户不知情或未授权的情况下秘密收集个人信息（浏览历史、输入的密码、地理位置等），并将这些敏感数据发送给第三方用于商业或恶意目的。



05 社会工程学攻击 (Social Engineering)

社会工程学攻击利用的不是技术漏洞，而是人的心理弱点，如信任、恐惧、疏忽等，是网络攻击中最具欺骗性的手段之一。



钓鱼邮件 (Phishing)

发送看似来自可信机构的欺骗性电子邮件，诱骗用户点击恶意链接、下载附件或输入敏感信息。



弱口令 / 暴力破解

Weak Password / Brute Force

利用用户使用生日、姓名等简单密码的习惯，配合自动化工具尝试海量密码组合，以极低的成本快速破解账户权限。



社工诈骗 / 冒充

Impersonation Scams

攻击者伪装成IT管理员、上级领导或权威机构人员，利用“服从权威”和“紧急事态”的心理，骗取信任后，诱导受害者提供敏感信息或执行资金转账。

PART 02

Web常见攻击技术深度解析

DEEP DIVE INTO COMMON WEB ATTACKS

01 SQL注入 (SQL Injection)

漏洞原理

SQL注入是Web应用中最经典、危害最大的漏洞之一，其本质是代码与数据未做隔离。

当Web应用程序将用户的输入直接拼接到SQL查询语句中，而没有进行任何过滤或转义时，攻击者可以通过构造特殊的输入，篡改SQL语句的逻辑，从而执行非授权的数据库操作。

主要危害

- 数据泄露

读取整个数据库，窃取用户账号、密码、敏感个人信息等核心资产。

- 数据破坏/篡改

任意修改或删除数据，甚至执行高危操作如`DROP DATABASE`，导致业务停摆。

- 权限提升

在特定配置下，可进一步执行系统命令，完全接管服务器权限。

典型示例：绕过登录

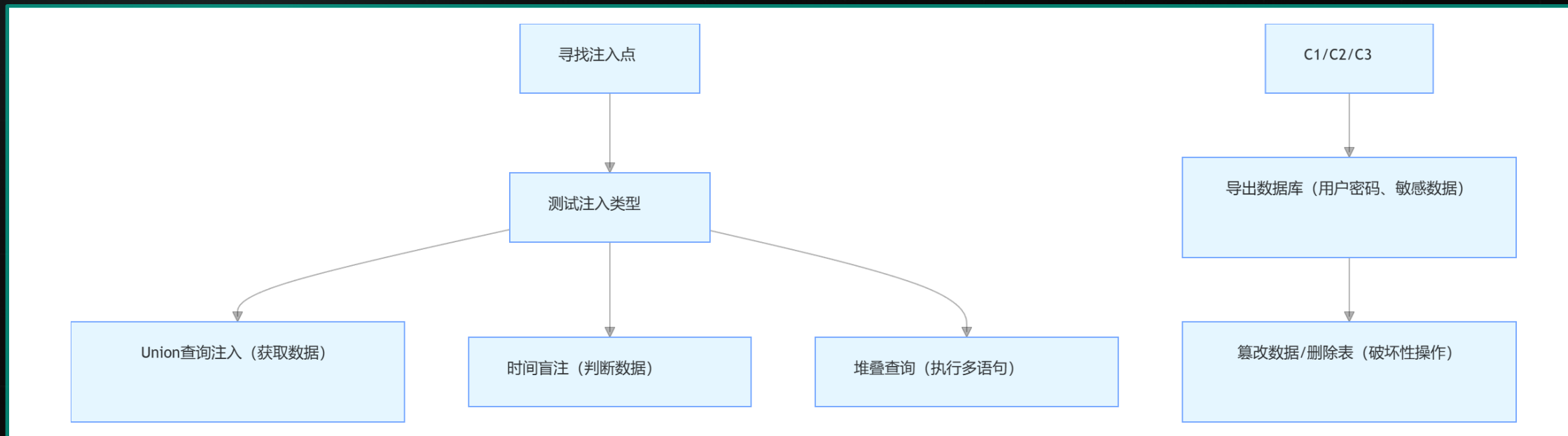
攻击者在用户名输入框输入特殊构造的内容，密码任意：

' OR '1'='1 --

```
SELECT * FROM users WHERE  
username=' ' OR '1'='1 --'  
AND password='任意值';
```

逻辑恒真 + 注释密码部分 = 成功登录

SQL注入攻击流程详解



攻击逻辑：判断注入点 → 确定字段数 → 联合查询 → 爆破表/列名 → 获取核心数据

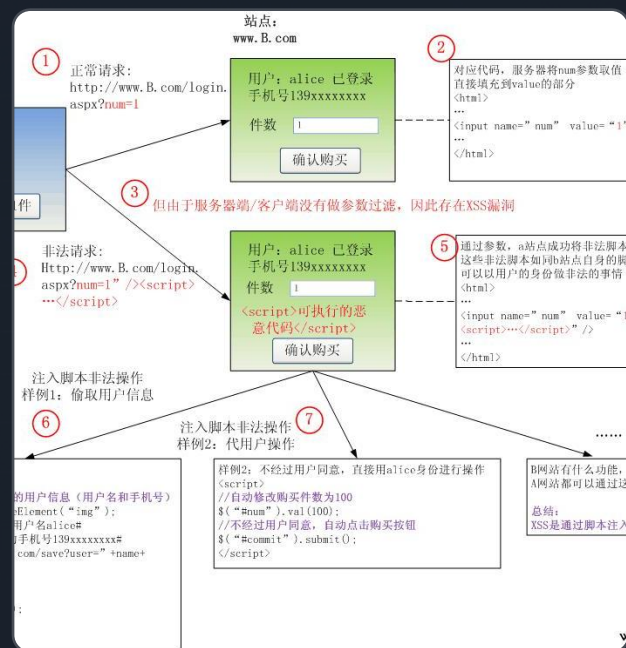
层层渗透，如“剥洋葱”般逐步获取数据库核心机密，每一步都可能暴露关键信息

02 XSS跨站脚本 (Cross-Site Scripting)

XSS攻击允许攻击者在目标网站上注入恶意脚本，当其他用户访问该网站时，脚本会在用户的浏览器中执行。其本质是网站的安全验证机制存在漏洞，错误地信任并执行了不可信的用户输入。

三种攻击类型

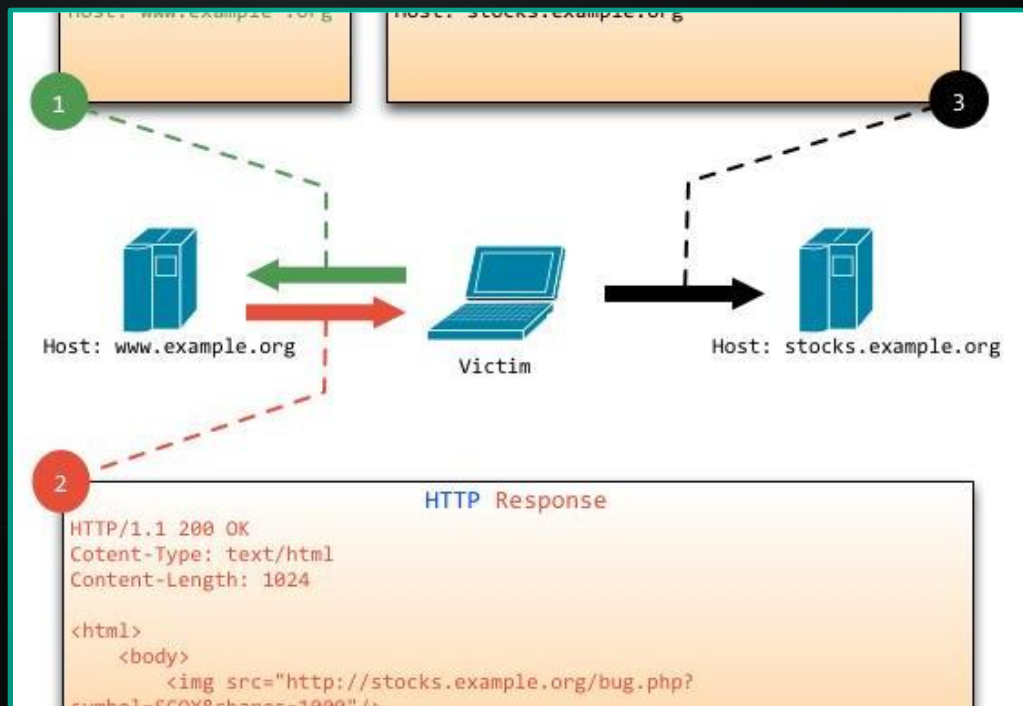
- 1. 存储型 (Stored XSS):** 最危险的类型。恶意脚本被永久存入网站数据库，所有访问该页面的用户都会触发攻击。
- 2. 反射型 (Reflected XSS):** 非持久化。脚本通过构造恶意URL，诱骗用户点击后触发，仅在一次请求中生效。
- 3. DOM型 (DOM-based XSS):** 漏洞存在于前端代码。通过URL修改页面DOM结构来执行恶意代码，数据不经过服务器。



主要安全危害

- 会话劫持:** 窃取用户Cookie凭证, 完全冒充用户身份登录, 执行任意操作。
- 钓鱼欺诈:** 在页面中注入并弹出伪造的登录框或支付界面, 诱导用户输入敏感信息。
- 页面篡改:** 随意修改网页内容、植入恶意广告或重定向到钓鱼网站, 破坏网站声誉。

03 CSRF 跨站请求伪造 (Cross-Site Request Forgery)



利用浏览器自动携带 Cookie 的机制，冒用用户身份发起请求



攻击本质：“借刀杀人”

攻击者诱导用户，利用用户在目标网站的已登录状态 (Cookie)，在用户不知情的情况下，以用户名义执行非自愿的敏感操作。



典型攻击五步法

① 用户登录网站A并生成Cookie → ② 未退出访问恶意网站B → ③ B向A发起敏感请求 → ④ 浏览器自动带上A的Cookie → ⑤ 网站A验证Cookie通过并执行操作



核心危害

攻击者可冒充用户身份执行敏感操作，如：资产转账、修改账号密码、发表不当言论、恶意删除或篡改数据等。

04 文件上传漏洞(File Upload Vulnerability)

漏洞原理

Web应用在处理用户上传的文件时，缺乏对文件的类型、后缀或内容的严格校验与过滤。

这使攻击者能够上传包含恶意代码的脚本文件（如 .php, .asp）。当该文件通过 Web 访问时，服务器会解析并执行其中的恶意指令，从而接管服务器。

常见绕过手段

- **前端校验绕过**：禁用JS脚本，或使用抓包工具直接修改上传请求。
- **MIME类型绕过**：篡改 HTTP 请求头中的 Content-Type。
- **扩展名绕过**：利用解析漏洞使用 .php3/.pHp 等特殊或大小写混合后缀。
- **图片马绕过**：在恶意代码前拼接图片文件头（如GIF89a）伪装成图片。

严重危害

远程代码执行 (GetShell)

一旦攻击者成功上传 WebShell，即获得了服务器的远程访问和控制权限。

后果包括：执行任意系统命令、窃取敏感数据、植入勒索病毒、利用服务器发起 DDoS 攻击等。

文件上传漏洞攻击流程详解



01. 准备与绕过：植入Webshell

攻击者构造恶意脚本文件，利用网站未做校验或校验逻辑缺陷，通过各类绕过技术，将Webshell成功上传至目标服务器目录。



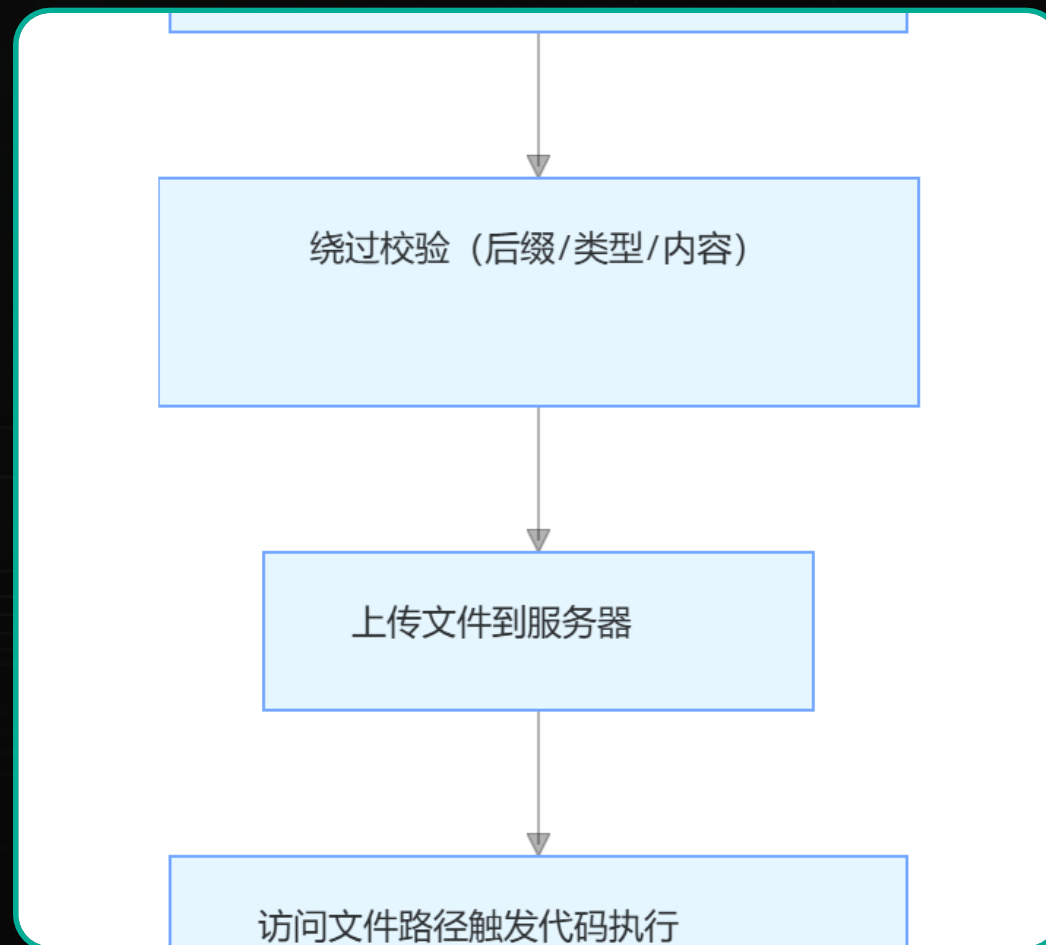
02. 连接与渗透：激活后门

通过蚁剑、菜刀等专业管理工具，连接并访问已上传的Webshell脚本，突破网站应用层的隔离，执行任意系统命令。



03. 提权与控制：接管服务器

在获取Web权限后，攻击者利用服务器漏洞进行提权，最终获取服务器的Root或Administrator权限，实现完全控制。



总结与回顾



攻击技术全景

- **信息收集**：渗透测试与攻击实施的首要步骤，寻找突破口。
- **DoS/DDoS**：消耗资源，破坏目标服务的可用性。
- **局域网攻击**：利用内部网络的信任机制进行横向渗透。
- **恶意代码 & 社工**：利用技术漏洞与人性弱点达成入侵目的。



Web 攻击核心漏洞

- **SQL注入 & 上传漏洞**：代码与数据未隔离，直接执行恶意代码。
- **跨站脚本 (XSS)**：信任了不可信的输入，导致恶意脚本执行。
- **跨站请求伪造 (CSRF)**：冒用用户的合法身份，执行未授权操作。



核心防御原则：永远不要信任用户的任何输入！



Q & A

感谢聆听

THANKS FOR LISTENING